AWS Cloud Security, Monitoring & Compliance

Encryption

Key Management Service (KMS)

- Encryption Service for **software**
- AWS manages the encryption keys for us, we won't get the key
- Automatic Encryption:
  - CloudTrail Logs
  - S3 Glacier
  - Storage Gateway
- Opt-In
  - EBS
  - S3 (SSE-S3 enabled by default, SSE-KMS opt in)
  - Redshift
  - RDS
  - EFS drives

CloudHSM

- AWS provides encryption **hardware**
- You manage your own encryption keys entirely

AWS Certificate Manager (ACM)

- SSL/TLS Certificates
- Provide **in-flight encryption** for HTTPS
- Support public and private TLS certificates
- Free for Public TLS

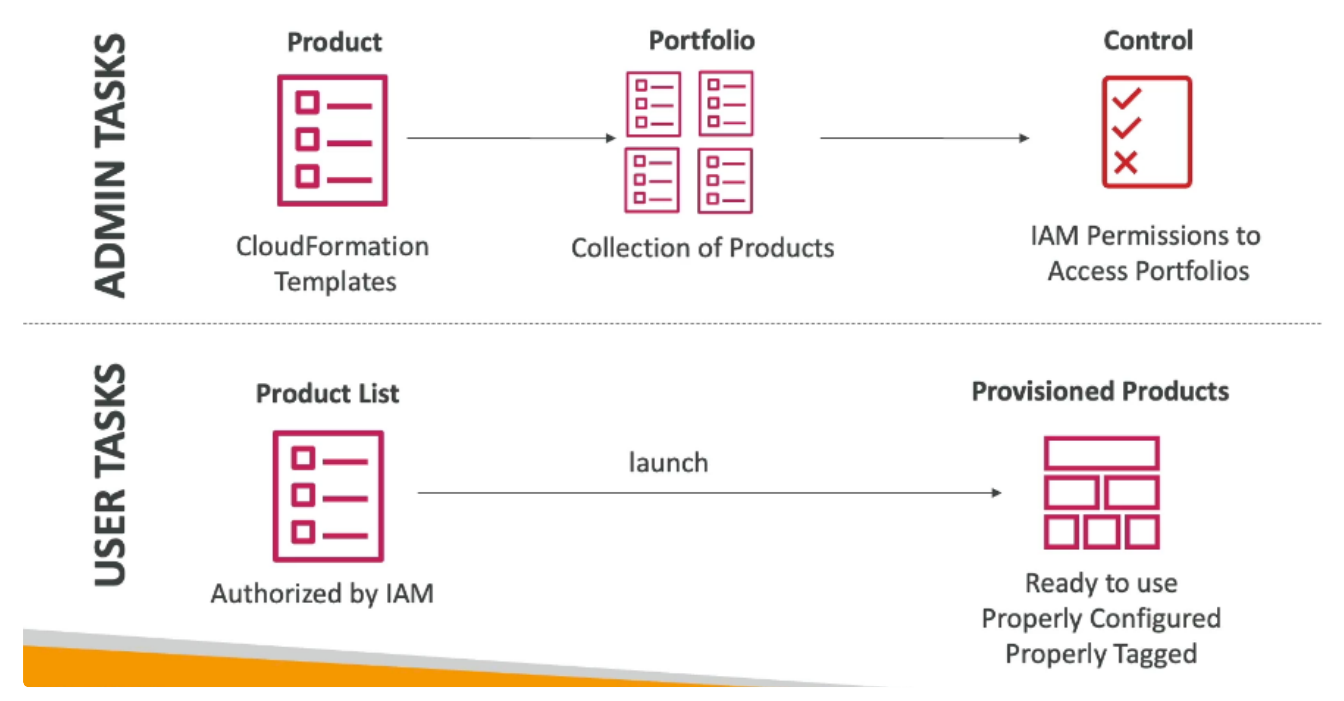
Secret Manager

- Storing secrets like passwords, not free
- Can force rotations of secrets every X days with Lambda's collaboration
- Integrated with RDS
- Encrypted using KMS

Compliance

Service Catalog

- Quick self-service portal to launch a set of authorized products pre-defined by admins
- VMs, databases, storage options
- To meet organization compliance requirements



Artifact

- AWS compliance documentations from third-party auditors, AWS agreements

Trusted Advisor

- Recommendation on:
  - Cost Optimization
  - Performance
  - Security
  - Fault Tolerance
  - Service limits
  - Operational Excellence
- Business(Full set)
- Enterprise(Full set)

Support Plans

Basic:

- Free
- Customer Service & Communities - 24/7 access to customer service, documentation, whitepapers, and forums
- Trusted Advisor - Access to the 7 core checks and guidance for best practices
- Personal Health Dashboard - A personalized view of the services health, and alerts when impacted

Developer:

- + Business hours email access to **Cloud Support Associates**
- + Unliminited cases/contacts

Business Support Plan(24/7):

- Intended to used of you have **production workloads**
- +Trusted Advisor - Full set of checks + API
- + 24/7 phone, email, and chat to Cloud Support Engineers
- + Access to Infrastructure Event Management

Enterprise On-Ramp Support Plan(24/7):

- Intended to be used for **production or business critical workloads**
- +Technical Account Managers(TAM)
- +**Concierge Support Team** (for billing and account best practices)
- + Access to Infrastructure Event Management, Well-Architected & Operations Reviews

Enterprise Support Plan(24/7):

- Intended to be used for **mission critical workloads**
- +**designated** Technical Account Managers(TAM)
- + Access to **AWS Incident Detection and Response** (for additinoal fee)

Monitoring

CloudWatch

Metrics

- Provide metrics for **every** service, CPU utilizaiton, Network...
- timestamps
- Cloudwatch Dashboards
- Custom Metrics

Alarms

- Trigger notifications for metrics
- Actions
  - Auto Scaling
  - EC2 Actions: terminate reboot...
  - SNS notifications
- create billing alarms

Logs

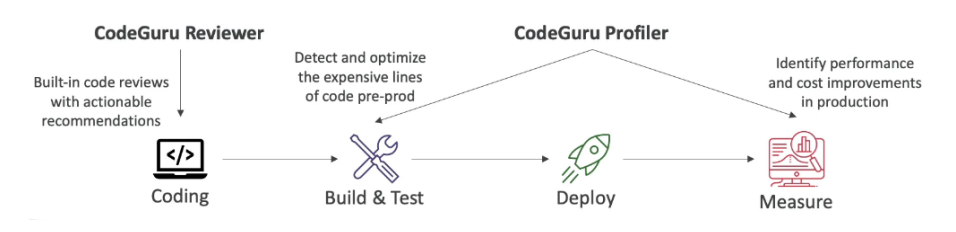
- Collect logs files from Elastic Beanstalk, ECS, Lambda, CloudTrails, CloudWatch Logs Agents, Route53
- Enables real-time monitoring
- Adjust log retention
- For EC2 and on-premise server, install CloudWatch Logs Agents to enable the push, and adjust IAM permissions for EC2

X-Ray

- **service graph**
- visual analysis of applications for **distributed tracing**
- **Troubleshooting** performance(bottlenecks)
- Understand dependencies in a **microservice architecture**
- Pinpoint service issues
- Review request behavior
- Find errors and exceptions
- Identify users that are impacted

CodeGuru

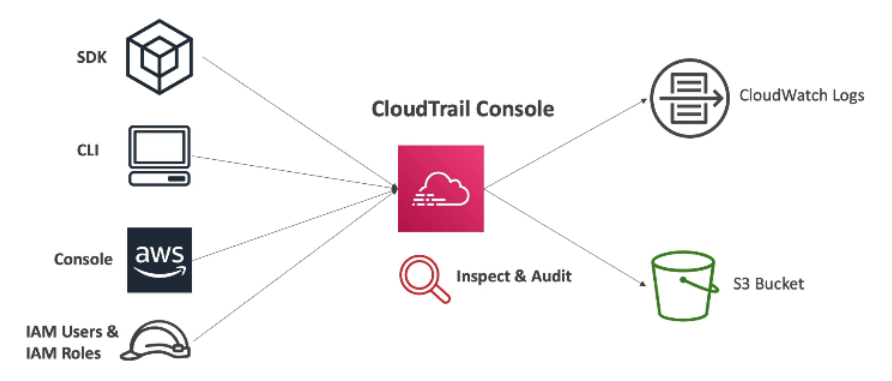
- ML powered service for **automated code reviews** and application performance recommendations
  - Reviewers: automated code review for static code analysis(**dev**)
  - Profiler: visibility/recs about application performance during **production**


CodeGuru Reviewer
Built-in code reviews with actionable recommendations
Detect and optimize the expensive lines of code pre-prod
CodeGuru Profiler
Identify performance and cost improvements in production
Coding
Build & Test
Deploy
Measure

CloudTrail

- Provides governance, compliance and audit for your account
- Enabled by default
- **History of events/API calls** made within account by:
  - Console
  - SDK
  - CLI
  - AWS Services
- Can put logs from CloudTrail into CloudWatch Logs or S3
- A trail can be applied to all Regions or a single Region
- If a resource is deleted in AWS, investigate CloudTrail first

Insights: automated analysis of CloudTrail events



Health Dashboard

Service History

- Formerly, AWS Service Health Dashboard - **General status of AWS services**
- Show all regions, all services health
- Show historical information for each day
- Has an RSS feed you can subscribe to

Your Account

- Formerly Personal Health Dashboard(PHD)
- Provide alerts and remediation guidance when AWS is experiencing events that may impact you
- **Personalized view into the performance and availability** of the AWS services underlying your resources
- dashboard for relevant and timely info, manage and proved proactive notifications to schedule activities
- Aggregate data from your organization

Security

Firewall Manager

- Manage at an **Organization** level: applied to new resources and all current and future accounts
- Manage **Security Policy**
  - VPC Security Groups for EC2, ALB
  - WAF rules
  - AWS Shield Advanced
  - AWS Network Firewall

WAF & Shield

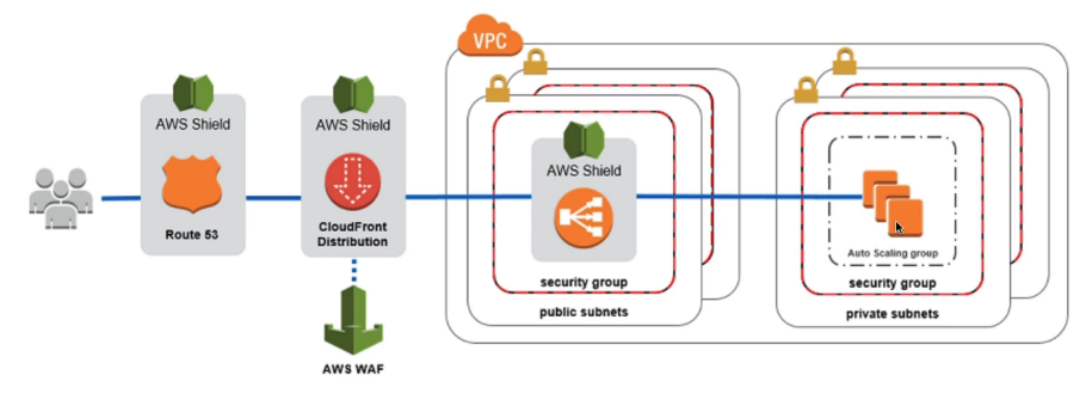
DDOS Protection

Shield Standard: Protects against DDOS attack for your website and applications, free

Shield Advanced: 24/7 support, more expensive

Web Application Firewall(WAF):

- Filter specific requests based on rules: IP addesses, HTTP components, SQL injections, Rate based Rules
- on Layer 7(HTTP), Layer 4 is TCP
- Web Access Control List(**ACL**)

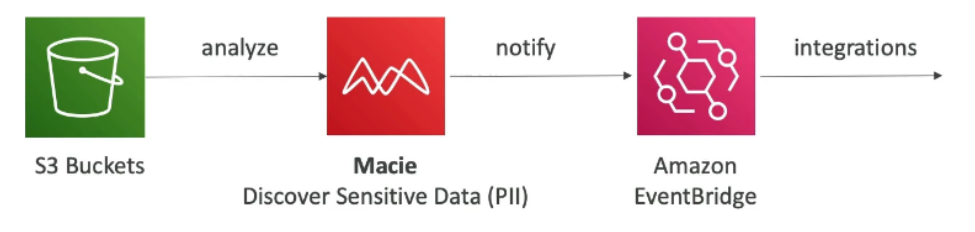


Network Firewall

- Protect entire VPC against network attacks
- Layer 3 to Layer 7

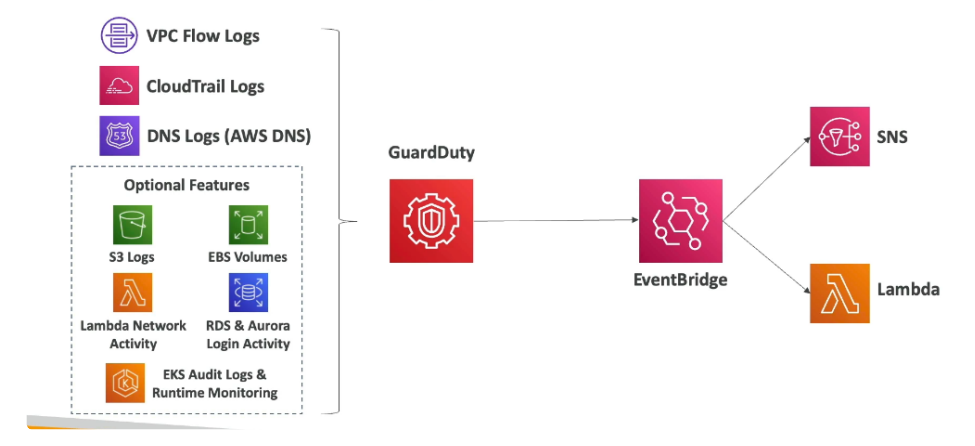
Macie

- Use ML and pattern matching to discover and protect **sensitive data** in **S3**
- Can alert you to **personally identifiable information**(PII)



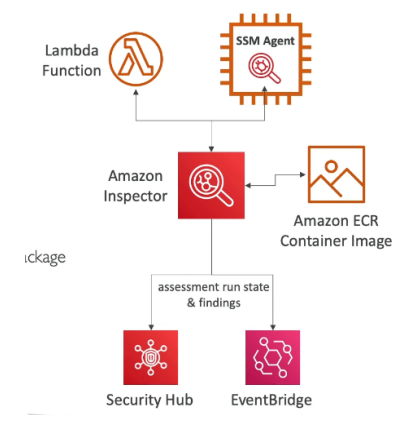
GuardDuty

- Uses **ML**, **anomaly detection**, 3rd Party data to discover **malicious behavior**
- 30 days trials
- Protect against Crypto Currency Attacks
- Input logs data -> EventBridge -> Lambda -> SNS



Inspector

- Automated **Security Assessments** for **EC2**, Container Images pushed to **ECR**, **Lambda** Functions
- Reporting & Integration with AWS Security Hub
- Send findings to EventBridge



IAM Access Analyzer

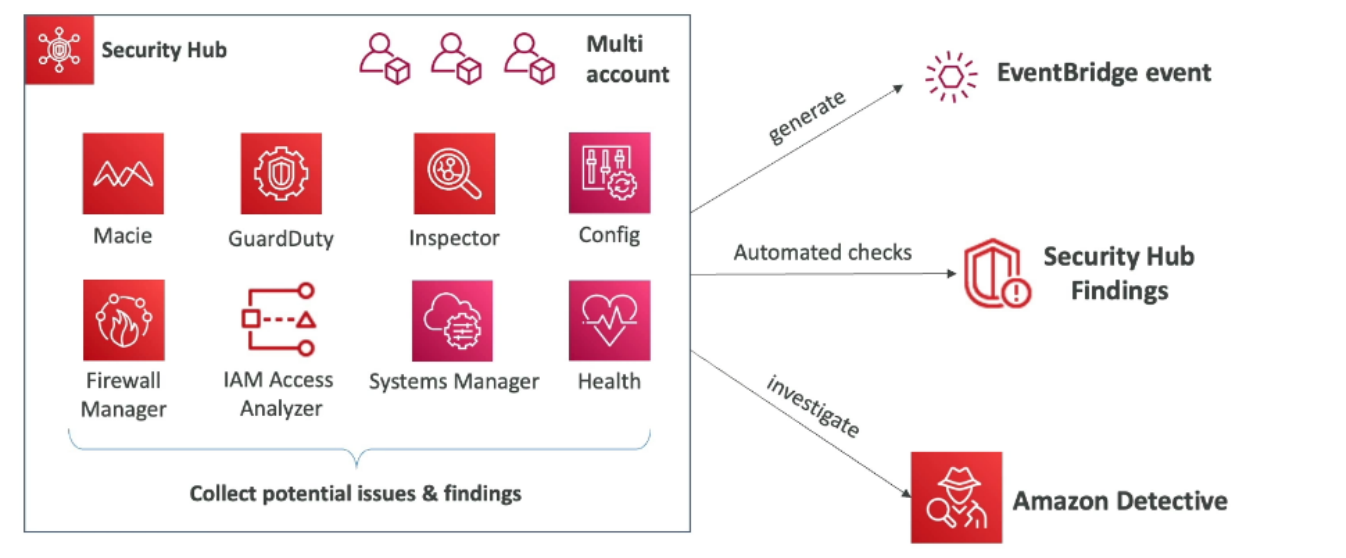
- Find out which resources are shared externally

Config

- Auditing and recording **compliance** of your AWS **resources**
- Record **configurations** and changes over time
- Stored in S3, and analyzed by Athena
- Receive alerts form SNS
- Per-Region Service, but can be aggregated across regions and accounts
- View compliance, configuration of resource over time
- View **CloudTrail API calls** if enabled

Security Hub

- Central security tool to manage security across several accounts
- Automate security checks
- Dashboard
- Aggregate: Config, GuardDuty, Inspector, Macie, IAM Access Analyzer, AWS System Manager, AWS Firewall Manager, AWS Health, AWS Partner Network Solutions

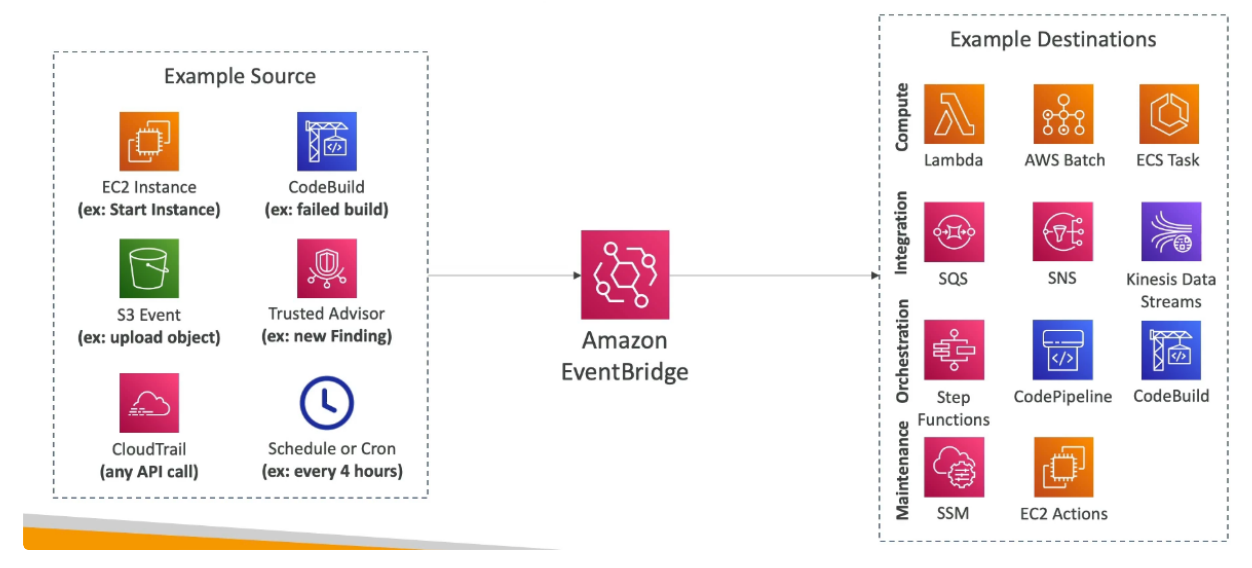


Detective

- Analyze the root cause of issues or suspicious activities using ML and graphs
- Automatically collects and processes events from VPC Flow Logs, CloudTrail, GuardDuty and create a unified view
- Produces visualizations

EventBridge

- Formerly CloudWatch Events
- Schedule like Cron Jobs, and can trigger Lambda
- Default Event Bus: EC2, Lambda, S3
- Partner Event Bus: Datadog, Zendesk
- Can do many



Organization

Organizations

- Global Service
- Allows to manage multiple AWS accounts
- The main account is the master account
- Cost Benefit:
  - Consolidated Billing
  - Discounted and aggregated usage
  - Pooling of Reserved EC2 instances
- API to automate AWS account creation
- Restrict account privileges using **Service Control Policies (SCP)**

Multi Account Strategies

- per department, per cost center, per dev/test/prod, per SCP, per VPC
- Use tags for billing purposes
- Centralized CloudTrail logs into S3

Consolidated Billing

- Combined Usage
- One Bill
- Turn off Reserved Instances discount sharing

Control Tower

- Easy way to set up and govern a secure and compliant multi account environment
- Automatically set up AWS Organizations to manage SCPs
- Guardrails to automate ongoing policy management
- Detect policy violations
- Monitor compliance

Resource Access Manager(RAM)

- Share AWS resources that you own within your Organization or other AWS accounts
- Avoid resource duplication
- Resources:
  - Aurora
  - VPC subnets
  - Transit Gateway
  - Route 53
  - EC2 Dedicated Hosts
  - License Manager Configs